

AI Vendor Assessment Questionnaire

Comprehensive Due Diligence Guide for Evaluating AI Vendors
Across Security, Privacy, Ethics & Governance

13 Sections

70 Questions

Scored 0-4

How to Use This Guide

1. **Send** the questionnaire to the vendor during procurement or renewal.
2. **Score** each response using the 0-4 scale.
3. **Review red flags** and evidence gaps requiring deeper investigation.
4. **Calculate** overall percentage and apply decision thresholds.
5. **Decide** using the thresholds on Page 1.

Scoring Methodology & Decision Thresholds

Response Scoring Scale

Score	Meaning	Criteria
0	Not Addressed	No response or capability does not exist
1	Ad Hoc / Informal	Some awareness but no formal process or documentation
2	Developing	Partial implementation; documented but inconsistently applied
3	Defined & Implemented	Formal process, consistently applied, evidence available
4	Optimised & Measured	Continuous improvement, metrics tracked, independently validated

Decision Thresholds

Overall %	Decision	Action
85-100%	Approve	Proceed with standard contract terms
70-84%	Conditional	Approve with remediation plan & timeline
50-69%	Escalate	Requires CISO/DPO review and risk acceptance
0-49%	Reject	Do not proceed; material risk unacceptable

Weighting

Default equal weighting applies. High-risk AI use cases (autonomous decisions, sensitive data) should increase weighting on Sections 1, 2, 5, 6, and 10.

Vendor Instructions

Purpose: This assessment evaluates your organisation's security, privacy, and governance posture as part of our third-party risk management process.

How to Complete This Assessment

- **Answer every applicable question** using the Score column (0-4 scale defined on the Scoring Methodology page).
- **Mark N/A** if a question is not applicable to your service scope. You must provide a written justification in the Evidence column.
- **Provide evidence** for each response – policy references, screenshots, certificate numbers, or links to documentation.
- **Return within 10 business days** unless otherwise agreed with your assessor contact.

Evidence Expectations

- Policies must be dated within 12 months and formally approved.
- Certifications (ISO 27001, SOC 2, etc.) must be current and in-scope.
- Technical controls should be evidenced with configuration exports or architecture diagrams.
- Where controls are partially implemented, explain the roadmap and timeline.

Scoring Impact

- Questions marked N/A are **excluded from the denominator** – they do not penalise your score.
- Each section produces a subtotal percentage; the overall score is a weighted average of applicable sections.
- A score below 60% in any critical section may trigger enhanced due diligence requirements.

Confidentiality

All responses are treated as confidential and protected under our mutual NDA. Assessment results are shared only with authorised risk and procurement stakeholders.

Section 1: AI Governance & Accountability

Evaluates organisational commitment to responsible AI through leadership, policy, and oversight structures.

#	Question	Score	Evidence Required
1.1	Does your organisation have a dedicated AI governance framework or policy?		AI governance policy document, board-approved framework
1.2	Is there a named individual or committee accountable for AI risk and ethics decisions?		Org chart showing AI ethics role, committee charter
1.3	How do you classify AI systems by risk level, and what controls differ between tiers?		Risk tiering methodology, control mapping per tier
1.4	What training do staff receive on responsible AI use and AI-specific risks?		Training records, curriculum, completion rates
1.5	How frequently is your AI governance framework reviewed and updated?		Review cadence documentation, change logs
1.6	Do you maintain an AI system inventory/register covering all production models?		AI register/inventory extract

Red Flags to Watch

- No written AI governance policy or board-approved framework.
- No named accountable owner for AI risk and ethics decisions.
- No central inventory of production AI systems.

Section 2: Data Governance & Privacy

Assesses data lifecycle management, privacy compliance, and data quality for AI systems.

#	Question	Score	Evidence Required
2.1	How is training data sourced, and what due diligence is performed on data provenance?		Data provenance documentation, source agreements
2.2	What data classification scheme do you apply to AI training and inference data?		Data classification policy, labelling examples
2.3	How do you ensure compliance with GDPR, CCPA, or applicable privacy regulations for AI processing?		DPIA, privacy impact assessment, legal basis documentation
2.4	What mechanisms exist for data subjects to exercise their rights (access, deletion, correction)?		DSR process documentation, response time metrics
2.5	How do you handle data retention and deletion for AI training datasets?		Retention schedule, deletion procedures
2.6	What data quality controls are in place for AI training and operational data?		Data quality metrics, validation procedures

Red Flags to Watch

- Cannot explain training data sources or provenance.
- No DPIA or unclear legal basis for AI processing.
- No defined retention or deletion process for AI datasets.

Section 3: Model Development & Validation

Examines rigour of model development lifecycle, testing, and validation practices.

#	Question	Score	Evidence Required
3.1	Describe your model development lifecycle from ideation to production deployment.		MDLC documentation, stage-gate criteria
3.2	What testing and validation methodologies are applied before model deployment?		Test plans, validation reports, acceptance criteria
3.3	How do you test for and mitigate bias in model outputs?		Bias testing reports, fairness metrics, mitigation strategies
3.4	What version control and model lineage tracking do you maintain?		Model registry, version control system, lineage graphs
3.5	How do you handle model reproducibility and experiment tracking?		Experiment tracking platform, reproducibility documentation
3.6	What peer review or independent validation processes exist for models?		Review board minutes, independent audit reports

Red Flags to Watch

- No formal model testing before production deployment.
- No bias testing or fairness validation evidence.
- No model versioning, lineage, or reproducibility records.

Section 4: Security & Infrastructure

Evaluates security controls protecting AI systems, infrastructure, and the ML pipeline.

#	Question	Score	Evidence Required
4.1	What security controls protect your AI/ML pipeline from adversarial attacks (data poisoning, model extraction, evasion)?		Threat model, adversarial testing results, security architecture
4.2	How is access to models, training data, and inference endpoints controlled?		Access control matrix, RBAC configuration, authentication mechanisms
4.3	What encryption is applied to data at rest, in transit, and during processing?		Encryption standards document, certificate configurations
4.4	Describe your vulnerability management process for AI infrastructure.		Vulnerability scan reports, patching SLAs, remediation metrics
4.5	What logging, monitoring, and alerting exists for AI system security events?		SIEM integration, alerting rules, log retention policy
4.6	How do you secure the CI/CD pipeline for model deployment?		Pipeline security controls, code signing, approval gates

Red Flags to Watch

- No adversarial threat modelling for ML-specific attacks.
- Weak access control around models, training data, or endpoints.
- No encryption evidence for sensitive AI data flows.

Section 5: Transparency & Explainability

Assesses ability to explain AI decisions and provide meaningful transparency to stakeholders.

#	Question	Score	Evidence Required
5.1	How do you provide explanations for AI-driven decisions to end users and affected parties?		Explainability documentation, XAI tools used, user-facing explanations
5.2	What model documentation (model cards, datasheets) do you maintain and share?		Model cards, datasheet for datasets, technical documentation
5.3	How do you communicate AI system limitations and confidence levels to users?		User documentation, confidence score displays, limitation disclosures
5.4	Do users know when they are interacting with an AI system?		Disclosure mechanisms, UI indicators, terms of service
5.5	What audit trail exists for AI decisions, and how long is it retained?		Audit log samples, retention schedule, immutability controls

Red Flags to Watch

- Black-box model with no meaningful explanation capability.
- Users are not told when they are interacting with AI.
- No retained audit trail for AI-driven decisions.

Section 6: Fairness & Bias Management

Evaluates proactive measures to identify, measure, and mitigate unfair bias.

#	Question	Score	Evidence Required
6.1	What fairness metrics do you track, and what thresholds trigger remediation?		Fairness metric definitions, threshold documentation, dashboards
6.2	How do you assess impact on protected groups and vulnerable populations?		Impact assessments, demographic analysis, stakeholder consultations
6.3	What processes exist for individuals to challenge AI decisions they believe are unfair?		Appeals/challenge process, escalation path, resolution metrics
6.4	How do you ensure training data is representative and does not encode historical biases?		Data representativeness analysis, bias audits, sampling methodology
6.5	Do you conduct regular third-party bias audits?		Third-party audit reports, auditor credentials, remediation actions

Red Flags to Watch

- No fairness metrics or thresholds are defined.
- No protected-group impact assessment has been performed.
- No process for users to challenge unfair AI decisions.

Section 7: Reliability & Performance

Assesses operational reliability, monitoring, and performance management in production.

#	Question	Score	Evidence Required
7.1	What SLAs/SLOs do you offer for AI system availability and performance?		SLA documentation, uptime metrics, performance benchmarks
7.2	How do you monitor for model drift and degradation in production?		Drift detection tools, monitoring dashboards, alert thresholds
7.3	What is your process for model retraining or rollback when performance degrades?		Retraining triggers, rollback procedures, change management process
7.4	How do you handle graceful degradation when AI components fail?		Failover architecture, fallback mechanisms, incident playbooks
7.5	What capacity planning exists for AI inference workloads?		Capacity plans, scaling policies, load testing results
7.6	How do you manage AI system dependencies and supply chain risks?		Dependency mapping, SBOM for ML, third-party risk assessment

Red Flags to Watch

- No production monitoring for model drift or degradation.
- No rollback or retraining trigger when performance drops.
- No failover path if AI components become unavailable.

Section 8: Incident Response & Continuity

Evaluates preparedness for AI-specific incidents, failures, and business continuity.

#	Question	Score	Evidence Required
8.1	Do you have an AI-specific incident response plan covering model failures, adversarial attacks, and unintended outputs?		AI incident response plan, playbooks, tabletop exercise records
8.2	What is your notification timeline for AI-related incidents affecting customers?		Notification SLA, communication templates, escalation matrix
8.3	How do you conduct post-incident reviews for AI failures?		Post-mortem reports, lessons learned, improvement tracking
8.4	What business continuity plans exist if AI systems become unavailable?		BCP documentation, manual fallback procedures, RTO/RPO targets
8.5	How do you handle customer data if the AI service is terminated?		Data return/destruction procedures, contractual terms, exit plan

Red Flags to Watch

- No AI-specific incident response plan or playbooks.
- No customer notification timeline for AI-related incidents.
- No business continuity plan for AI service failure.

Section 9: Third-Party & Supply Chain Risk

Examines management of AI supply chain, sub-processors, and third-party dependencies.

#	Question	Score	Evidence Required
9.1	What third-party AI models, APIs, or components are integrated into your solution?		Third-party component inventory, API dependencies list
9.2	How do you assess and monitor the security posture of AI sub-processors?		Sub-processor assessments, monitoring reports, contractual requirements
9.3	What controls ensure third-party model updates don't introduce risk?		Change management for third-party updates, testing gates, rollback capability
9.4	How do you manage open-source AI component risks (licensing, vulnerabilities, supply chain)?		OSS policy, license compliance checks, vulnerability scanning for ML libraries
9.5	What contractual protections do you maintain with your AI suppliers?		Supplier contracts, SLA pass-through, liability clauses

Red Flags to Watch

- Third-party AI models or APIs are not inventoried.
- Model or component updates bypass validation gates.
- No sub-processor monitoring or contractual flow-down controls.

Section 10: Regulatory Compliance & Legal

Assesses compliance with AI-specific regulations, standards, and legal obligations.

#	Question	Score	Evidence Required
10.1	How do you ensure compliance with the EU AI Act and its risk classification requirements?		EU AI Act compliance assessment, risk classification, conformity documentation
10.2	What AI-related certifications or standards do you hold or align with?		ISO 42001 certificate, SOC 2 report, NIST AI RMF alignment
10.3	How do you monitor and adapt to evolving AI regulations across jurisdictions?		Regulatory monitoring process, legal counsel engagement, compliance roadmap
10.4	What IP protections exist for customer data used in AI processing?		IP clauses in contracts, data usage terms, output ownership documentation
10.5	How do you handle cross-border data transfers for AI processing?		Transfer mechanisms (SCCs, adequacy decisions), data localisation options
10.6	What liability framework applies to AI-caused errors or harm?		Contractual liability terms, insurance coverage, indemnification clauses

Red Flags to Watch

- No EU AI Act or AI regulatory compliance roadmap.
- No clear IP or output ownership protections for customer data.
- No liability terms for AI-caused errors or harm.

Section 11: Human Oversight & Control

Evaluates mechanisms for meaningful human oversight and intervention in AI operations.

#	Question	Score	Evidence Required
11.1	What human-in-the-loop or human-on-the-loop mechanisms exist for high-risk decisions?		HITL process documentation, decision escalation criteria, override mechanisms
11.2	How can authorised users override, correct, or shut down AI system outputs?		Override controls, kill-switch documentation, correction workflows
11.3	What training do human reviewers receive to effectively oversee AI outputs?		Reviewer training programme, competency requirements, ongoing assessment
11.4	How do you prevent automation bias in human oversight processes?		Automation bias mitigation strategies, reviewer performance metrics
11.5	What escalation paths exist when AI systems produce unexpected or concerning outputs?		Escalation matrix, response procedures, on-call arrangements

Red Flags to Watch

- High-risk decisions are fully autonomous with no human review.
- No override, correction, or shutdown mechanism exists.
- Human reviewers receive no AI oversight training.

Section 12: Environmental & Social Impact

Examines broader environmental and societal considerations of AI operations.

#	Question	Score	Evidence Required
12.1	What is the environmental footprint of your AI training and inference operations?		Energy consumption metrics, carbon footprint reports, sustainability commitments
12.2	What steps have you taken to reduce the energy consumption of your AI systems?		Efficiency optimisation documentation, green compute initiatives
12.3	How do you assess and mitigate the broader societal impacts of your AI systems?		Social impact assessment, stakeholder engagement records
12.4	What measures ensure your AI systems do not contribute to job displacement without transition support?		Workforce impact assessment, transition support programmes

Red Flags to Watch

- No visibility into AI training or inference energy footprint.
- No documented efficiency or sustainability measures.
- No assessment of broader societal or workforce impact.

Section 13: Generative AI & LLM Risks

Context: This section addresses emerging risks specific to organisations deploying or integrating generative AI and large language models (LLMs) in their products or operations.

#	Question	Score	Evidence Required
13.1	Are controls in place to prevent and detect prompt injection attacks, both direct and indirect?		Input validation architecture, guardrail documentation, red-team testing reports
13.2	Are hallucination mitigation controls implemented, such as grounding, RAG, confidence scoring, or human-in-the-loop review?		Model architecture documentation, output validation procedures, accuracy metrics
13.3	Are clear boundaries defined for what data LLMs can access, process, and retain, with technical enforcement?		Data flow diagrams, access control configurations, data retention policies for AI systems, DLP evidence

Evidence Guidance: Provide AI-specific architecture documentation, model cards, responsible AI policies, and results from adversarial testing or AI red-teaming exercises.

Red Flags to Watch: No prompt injection defences, unrestricted LLM access to production data, no hallucination monitoring, or no AI-specific risk assessment conducted.

Appendix A: Framework & Standards Mapping

Section	NIST AI RMF	ISO/IEC 42001	EU AI Act	ISO 27001
1. Governance	GOVERN 1-6	5.1, 5.2, 5.3	Art. 9, 17	A.5
2. Data Governance	MAP 2.3, MANAGE 2.2	6.1, A.6.2	Art. 10	A.8
3. Model Development	MAP 1.5, MEASURE 2	6.2, A.6.3	Art. 9, 15	A.8.25
4. Security	MANAGE 2.4	A.6.6	Art. 15	A.8.1-8.34
5. Transparency	MAP 1.6, GOVERN 4	A.6.4	Art. 13, 52	-
6. Fairness	MAP 2.3, MEASURE 2.6	A.6.5	Art. 10, 71	-
7. Reliability	MEASURE 3, MANAGE 3	6.2, A.6.7	Art. 15	A.8.14
8. Incident Response	MANAGE 4	A.6.8	Art. 62	A.5.24-28
9. Supply Chain	GOVERN 6, MAP 3	A.6.9	Art. 28	A.5.19-23
10. Regulatory	GOVERN 1.2	4.1, 4.2	Art. 6, 43	A.5.31-36
11. Human Oversight	GOVERN 5, MANAGE 1	A.6.10	Art. 14	-
12. Environmental	MAP 2.2	A.6.11	Recital 27	-
13. Generative AI & LLM Risks	MEASURE 2, MANAGE 2	A.6.2, A.6.6	Art. 9, 15, 50	A.8

Appendix B: Evidence Pack Checklist

#	Evidence Item	Section	Received
1	AI Governance Policy / Framework Document	1	☐
2	AI System Register / Inventory	1	☐
3	Data Protection Impact Assessment (DPIA)	2	☐
4	Data Provenance & Lineage Documentation	2	☐
5	Model Validation & Testing Reports	3	☐
6	Bias Testing & Fairness Audit Reports	3, 6	☐
7	Security Architecture & Threat Model	4	☐
8	Penetration Test / Adversarial Testing Results	4	☐
9	SOC 2 Type II Report	4, 10	☐
10	ISO/IEC 42001 or ISO 27001 Certificate	10	☐
11	Explainability / Model Card Documentation	5	☐
12	AI Incident Response Plan	8	☐
13	Business Continuity / Disaster Recovery Plan	8	☐
14	Third-Party / Sub-Processor Register	9	☐
15	EU AI Act Conformity Assessment	10	☐
16	Human Oversight & Kill-Switch Documentation	11	☐
17	Environmental Impact / Carbon Footprint Report	12	☐
18	Training Records for AI Staff & Reviewers	1, 11	☐
19	Model Drift Monitoring Reports	7	☐
20	Data Retention & Deletion Procedures	2	☐
21	LLM Guardrail / Prompt Injection Test Results	13	☐
22	Generative AI Architecture / RAG Documentation	13	☐

Assessment Summary

Vendor Name: _____

Date: _____

Assessor: _____

Overall Score: _____ / 280

Decision: ☐ Approve ☐ Conditional ☐ Escalate ☐ Reject

Notes:
